PRODUCT REQUIREMENTS DOCUMENT - SUMMARY

Weekly Reports / Presentation Viewer

v0.1 Draft - 19 Oct 2026
Full PRD: datum-weekly-reports-prd.pdf

1. Problem and goal

The Product Team presents a weekly status deck (PPT/Canva) to each client brand outside Datum. Versions get mixed up, a deck can reach the wrong brand, there is no record of who published what, and clients receive the editable source file.

Goal: an authorized internal user uploads a PPT/PPTX for the *currently selected brand*, previews it, and publishes it. Authorized client users see **only the latest published report of their own brand** in an in-app presentation viewer. The original file is never sent to the client browser, and Datum offers no download, share, export or print.

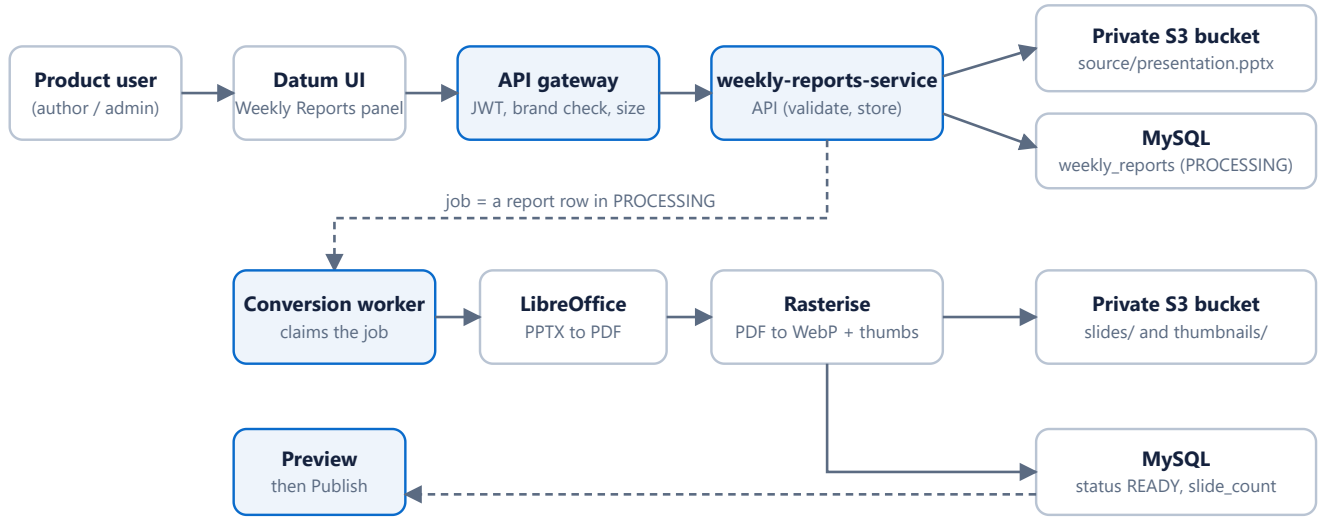
Non-goals (V1): slide editing, animations/video, historical reports for clients, Canva import, preventing screenshots.

2. Roles and permissions

Who	Can do	How
Author / admin / super_admin (internal)	View + manage: upload, preview, publish, unpublish, delete, version history	Elevated role. Implicit; checked in the backend.
Client user	View only: latest published report and viewer	New per-brand permission `weekly_reports_panel` (follows the repo's `*_panel` naming). Assigned in Access Control.
Anyone else	Nothing: no menu item, redirect, API 403	

Manage is **not grantable to clients**. The frontend only hides things; every API call is authenticated, permission-checked and brand-checked in the service.

3. How it works



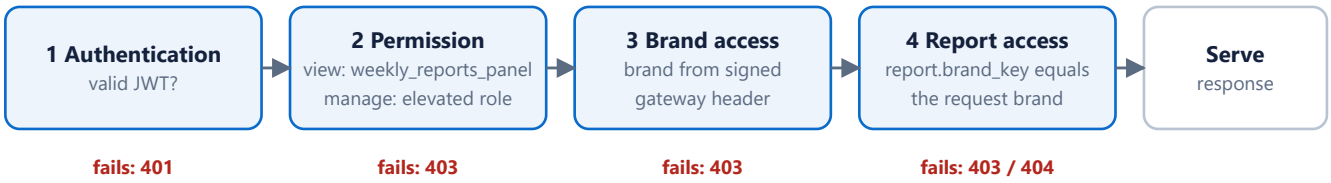
UI polls the status; the manager previews, then publishes. The viewer reads slides through the API.

Upload and processing (internal user)

- **Backend:** new `weekly-reports-service` (API + conversion worker) on the existing EC2 Docker Compose, behind the API gateway (prefix `/weekly-reports/`).
- **Conversion:** LibreOffice (PPTX to PDF), then per-slide WebP images (1920 px) and thumbnails (320 px).
- **Storage:** new dedicated **private** S3 bucket. Slides are streamed through the API after authorization; no public or presigned URLs.

4. Brand scoping and isolation

- The report's brand is the **current Datum brand**, sent as `brand_key` in the query string; the upload form has no second brand selector.
- The service trusts **only the gateway-signed** `x-brand-id`. A brand in the body or path that disagrees is rejected (400). Every query includes `brand_key`; a report id alone never grants access.
- The service must fail closed if `GATEWAY_SHARED_SECRET` is missing (analytics today skips the check when it is unset).



All four checks run in the service on every request. The browser's own state (selected brand, hidden menu items) is never trusted.

Authorization chain on every request

5. Lifecycle and versioning

States: PROCESSING → READY → PUBLISHED → UNPUBLISHED; conversion failure → FAILED (never visible to clients). A brand has **one** published report; publishing a new one automatically unpublishes the old one.

Versions: a new upload for the same brand and week becomes v2, v3... Nothing is overwritten. Clients see only the latest published version; internal users see the history and can republish an older one. Delete is a soft delete and is refused while PUBLISHED.

6. Viewer and client restrictions

Viewer

- Previous/next, "7 / 18", thumbnail rail, fullscreen, keyboard (arrows, PgUp/PgDn, Home/End, F).
- Slide 1 loads first; next slides prefetched; thumbnails lazy-loaded.
- Per-slide loading and retry state; light/dark theme.
- Dynamic watermark (brand, viewer email, date) burned into each slide on the server.

Clients get no

- Download, share, export, print, open-original, Canva source.
- Upload, replace, publish, unpublish, delete.
- Any endpoint that returns the source file (none exists, for any role).

> **Limit:** a browser cannot prevent screenshots or screen recording. The guarantee is that **the original file is never exposed to the client and Datum provides no download, export, sharing or original-file access**. The watermark and audit log deter and trace leaks; they do not prevent them.

7. Data and API

Tables (central MySQL, assumed): `weekly_reports` (brand_key, title, reporting_week, version, status, source_storage_key, slide_count, uploaded_by, published_at, deleted_at), `weekly_report_slides` (report_id, slide_number, image/thumbnail keys), `weekly_report_events` (audit).

Endpoint	Access	Purpose
GET /weekly-reports/latest	view	Latest PUBLISHED report of the brand (404 if none)
GET /weekly-reports/:id/slides/:n	view	Watermarked slide image (?size=thumb); re-authorized each call
POST /weekly-reports	manage	Upload (multipart: file, title, reporting_week); returns 202
GET /weekly-reports, POST /:id/publish, POST /:id/unpublish, DELETE /:id	manage	List versions, publish, unpublish, soft delete

Errors use Datum's `{ "error": "..." }` shape: 401 unauthenticated, 403 no permission / wrong brand, 404 nothing published, 409 illegal state, 413/415/422 bad file. Audit events: uploaded, version created, processed/failed, published, unpublished, deleted, access denied.

8. What exists today vs. what is new

Existing in Datum	New work
Gateway JWT + brand check and signed headers; `requirePermission` pattern; flat permission strings; Docker Compose on EC2; S3 SDK	New permission string (gateway + Access Control); new service and worker image (LibreOffice, rasteriser); new private bucket and IAM; nginx location with larger body limit
Sidebar / tab / route / permission-guard pattern in `App.jsx`; shadcn dialog, tabs, skeleton; toasts	Uploader, report card, version table and presentation viewer (no upload or viewer UI exists); audit table (no audit log exists)

The existing analytics upload route is **not** reused: it has no authorization, no size limit and returns public-style URLs.

9. V1 scope

V1	V1.1	V2+
Upload PPT/PPTX, convert, preview, publish, unpublish, delete; versioning; brand isolation; viewer; server-side watermark; audit events	Client view tracking; zoom; consider PDF upload and virus scanning	Canva URL import (always ending in the Datum viewer, never a Canva redirect); client history; publish notifications

10. Proposed performance targets (not existing requirements)

First slide visible p75 under 2 s (10 Mbps, 20-slide deck); prefetched next slide under 300 ms; slide image under 300 KB; thumbnail under 25 KB; 20-slide conversion p90 under 2 min; metadata API p95 under 300 ms.

11. Acceptance criteria (headline)

- **Upload:** elevated user can upload PPT/PPTX; the report is saved under the signed current brand; wrong type, oversize, macro-enabled or corrupt files are rejected; PROCESSING shows progress; failures end in FAILED and are invisible to clients.
- **Permissions:** no `weekly_reports_panel` means no menu, redirect, and 403 on every view API; clients calling manage APIs get 403.
- **Client:** sees only the latest published report of the active brand (or an empty state); can navigate, use thumbnails and fullscreen; no path to the source file or storage URL; watermark on every slide.
- **Brand isolation:** BBB user gets BBB report (200) but 403 for a PTS report, and the reverse; manipulated `report_id` or body `brand_key` never grants access (14 test scenarios in the full PRD).
- **Versioning:** a new upload keeps the old version; publishing v2 makes v2 the only client-visible report.

12. Assumptions and open questions

Assumptions (to confirm)

- 50 MB and 100-slide limits; all versions kept indefinitely.
- Internal users can see version history.
- One live report per brand; publish auto-unpublishes the previous one.
- Tables in the central MySQL (needs MySQL 8 for job claiming).
- LibreOffice rendering fidelity is acceptable; preview-before-publish is the safeguard.

Open questions

- Central vs per-brand database for the tables?
- Cross-brand access: 403 (as specified) or uniform 404?
- May internal users download the original from Datum? (V1: no one.)
- Allow PDF upload in V1 for better fidelity?
- Brand fonts needed on the worker; spare 1-2 GB RAM on EC2 for conversion?

> **Decisions made:** admin/author get everything, clients get one view-only permission; new `weekly-reports-service` ; new private S3 bucket; watermark and delete in V1; view tracking in V1.1.